

Introduction au PSSI (Plan de Sécurité des Systèmes d'Information)

1. Introduction

- Les systèmes d'information sont au cœur de l'activité des entreprises.
- Les menaces (cyberattaques, pannes, erreurs humaines) augmentent en fréquence et en gravité.
- Pour répondre à ces enjeux, les organisations mettent en place un **Plan de Sécurité des Systèmes d'Information (PSSI)**.

Définition :

Le PSSI est un document stratégique qui fixe les **règles, procédures et responsabilités** pour protéger les ressources informationnelles de l'entreprise.

Question de réflexion :

Que se passerait-il si une entreprise n'avait pas de PSSI ?

2. Objectifs du PSSI

Un PSSI vise à :

- **Confidentialité** : seules les personnes autorisées accèdent aux informations.
- **Intégrité** : les données restent exactes et non altérées.
- **Disponibilité** : les systèmes et données sont accessibles en temps voulu.
- **Conformité** : respect des lois et réglementations (RGPD, CNDP, ISO 27001...).
- **Culture de sécurité** : sensibiliser tous les acteurs de l'organisation.

3. Les acteurs du PSSI

Un PSSI implique plusieurs rôles :

- **Direction générale** : valide et soutient la politique.
- **DSI (Directeur des SI)** : pilote la mise en œuvre.
- **RSSI (Responsable Sécurité SI)** : élabore, contrôle et met à jour le PSSI.
- **Administrateurs techniques** : appliquent les règles sur les systèmes.
- **Utilisateurs** : doivent respecter les bonnes pratiques.

Le PSSI concerne **tout le monde**, pas seulement l'informatique.

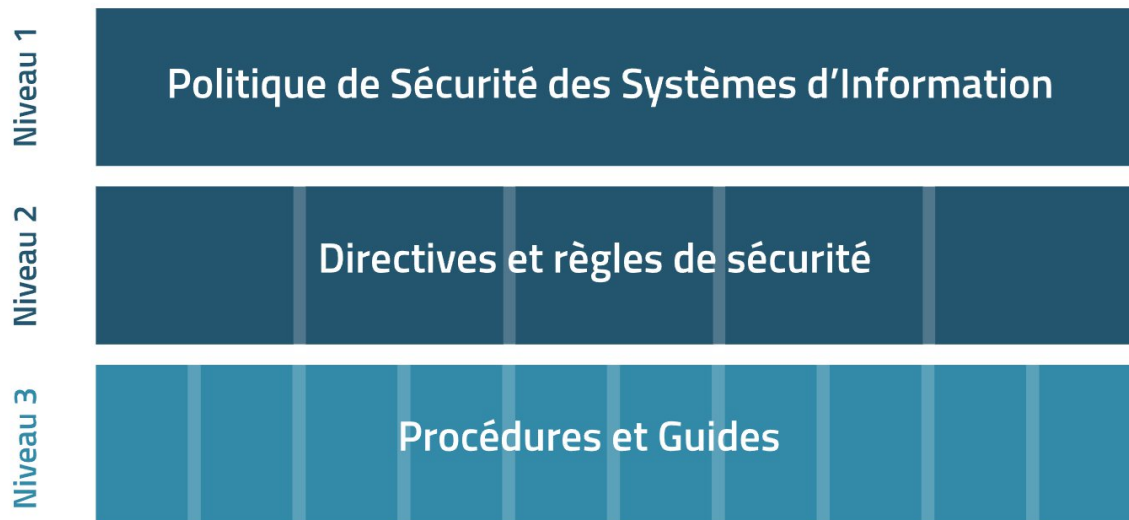
4. Les risques principaux couverts par le PSSI

Le PSSI anticipe et réduit les menaces suivantes :

1. **Cyberattaques externes** : phishing, ransomware, DDoS.
2. **Intrusions internes** : abus de droits, accès non autorisé.
3. **Pannes techniques** : serveurs, réseau, électricité.
4. **Perte ou fuite de données** : mauvaise manipulation, vol, absence de sauvegarde.

5. **Erreurs humaines** : clic sur lien malveillant, mot de passe faible.
6. **Non-conformité réglementaire** : sanctions légales ou financières.

5. Organisation hiérarchique



La figure illustre bien la **hiérarchie classique d'une Politique de Sécurité des Systèmes d'Information (PSSI)** en trois niveaux complémentaires :

1. **Niveau 1 – Politique de sécurité (PSSI globale)**
 - C'est le document cadre, validé par la direction.
 - Il définit les **principes généraux**, les **objectifs stratégiques** et l'**engagement de l'organisation** en matière de sécurité.
 - Exemple : « Protéger la confidentialité, l'intégrité et la disponibilité des informations critiques de l'entreprise. »
2. **Niveau 2 – Directives et règles de sécurité**
 - Ce sont les **règles pratiques et normatives** à appliquer par les différents métiers.
 - Elles traduisent la politique générale en exigences opérationnelles.
 - Exemple : « Les mots de passe doivent comporter au minimum 12 caractères et être renouvelés tous les 90 jours. »
3. **Niveau 3 – Procédures et guides**
 - Ce sont les **modes opératoires détaillés**, destinés aux utilisateurs et aux équipes techniques.
 - Ils expliquent *comment* mettre en œuvre les règles du niveau 2.
 - Exemple : guide pas-à-pas pour activer le chiffrement du disque sur un poste de travail.

En résumé, cette figure est pertinente car elle montre la logique **du stratégique vers l'opérationnel** :

- **La politique** donne le *quoi* et le *pourquoi*.
- **Les directives/règles** donnent le *quoi faire*.
- **Les procédures/guides** donnent le *comment faire*.

Cela évite que la PSSI reste trop théorique, car chaque niveau trouve son application pratique.

6. Structure type d'un PSSI

Un PSSI est organisé en plusieurs sections :

1. **Politique de sécurité** → règles générales, gestion des accès, bonnes pratiques.
2. **Classification des données** → publiques, internes, confidentielles, très sensibles.
3. **Procédures de sécurité** → gestion des incidents, sauvegardes, mises à jour.
4. **Plan de continuité et reprise** → scénarios de crise, RPO/RTO.
5. **Sensibilisation et formation** → campagnes de prévention, formations régulières.
6. **Audit et mise à jour** → vérification annuelle et mise à jour après incident majeur.

7. Structure type d'un PSSI (avec lien aux 3 niveaux hiérarchiques)

Niveau 1 – Politique de sécurité

- **Politique de sécurité** : principes généraux, objectifs stratégiques, responsabilités.
Exemple : « La protection des données sensibles est une priorité stratégique de l'organisation. »

Niveau 2 – Directives et règles de sécurité

- **Classification des données** : catégories (publiques, internes, confidentielles, très sensibles).
- **Règles générales de sécurité** : gestion des accès, mots de passe, contrôle des supports amovibles.
- **Plan de continuité et reprise** : exigences RPO/RTO, scénarios de crise, redondance.

Niveau 3 – Procédures et guides

- **Procédures de sécurité** :
 - Gestion Des Incidents (Qui Alerter, Comment Réagir),
 - Sauvegardes (Fréquence, Stockage, Restauration),
 - Mises A Jour (patch management).
- **Sensibilisation et formation** : guides pour employés, e-learning, exercices de phishing.
- **Audit et mise à jour** : checklist annuelle, procédures de correction après incident.

8. Focus : Gestion des incidents dans un PSSI

Un bon PSSI doit inclure une section complète sur la **gestion des incidents de sécurité** :

- **Définitions et classification** → typologie (malware, intrusion, fuite...), niveaux de criticité.
- **Organisation de la réponse** → équipe de réponse (CSIRT/CERT), rôles, escalade hiérarchique.
- **Détection et signalement** → monitoring, alertes, canaux de signalement, délais selon criticité.
- **Processus de réponse** → confinement, analyse, éradication, récupération, retour à la normale.

- **Communication de crise** → protocoles internes/externes, messages prédéfinis, porte-parole.
- **Aspects légaux** → notification aux autorités (CNIL, ANSSI...), délais réglementaires.
- **Ressources et outils** → forensique, sauvegardes, experts externes.
- **Continuité d'activité** → bascule sur systèmes de secours.
- **Retour d'expérience** → capitaliser les leçons apprises, mettre à jour les procédures.

9. Exemples de mesures concrètes dans un PSSI

1. **Authentification forte (MFA)** → protéger l'accès aux systèmes critiques.
2. **Sauvegardes automatiques et testées** → garantir la restauration après incident.
3. **Chiffrement des données sensibles** → protéger en cas de fuite ou vol.
4. **Pare-feu, IDS/IPS et antivirus** → bloquer et détecter les intrusions.
5. **Sensibilisation régulière des utilisateurs** → limiter les erreurs humaines.

10. Exemple simplifié : TechnoShop SARL

Contexte : PME de vente en ligne.

- **Objectif PSSI** : protéger les données clients et assurer la continuité du site.
- **Risques couverts** : ransomware, vol de données, panne serveur.
- **Mesures principales** :
 - Authentification MFA.
 - Sauvegardes quotidiennes testées.
 - Chiffrement des données sensibles.
 - Sensibilisation trimestrielle.
- **Plan de continuité** : serveur externe de secours (reprise sous 4h).

11. Étude de cas pratique

Scénario : une PME subit un ransomware.

- **Sans PSSI** → chaos, perte de données, arrêt d'activité prolongé.
- **Avec PSSI** → sauvegardes disponibles, gestion d'incident appliquée, reprise rapide.

L'impact est fortement réduit grâce au PSSI.

12. Conclusion

- Le **PSSI est un document stratégique** indispensable.
- Il couvre les risques majeurs : cyberattaques, pannes, pertes de données, erreurs humaines.
- Il propose des **mesures concrètes** : MFA, sauvegardes, chiffrement, pare-feu, formation.
- Sa réussite repose sur :
 - Un **engagement fort de la direction**.
 - Une **implication de tous les employés**.
 - Une **mise à jour régulière**.

Message final aux stagiaires :

La cybersécurité est une responsabilité partagée :

le PSSI fixe les règles du jeu pour protéger l'entreprise.